Threat Modeling Report

Created on 04/11/2026 01:21:48

Threat Model Name: Smart Tourism Software

Owner: Dênis Zeferino

Reviewer: Celso Hirata

Contributors: Celso Hirata

Description: Goals of the STPA Step 1 (AppSTPA report of 29 August 2026; Section 5.2.1 of the dissertation): G-1: Provide personalized tourism recommendations based on user preferences and location. G-2: Process personal data in full compliance with the LGPD (Brazilian General Data Protection Law). G-3: Maintain high availability and reliability of the service. G-4: Protect sensitive data inferred from location patterns. G-5: Adopt data minimization and protection by design in all phases of the life cycle.

Assumptions: Assumptions of the STPA Step 1 (AppSTPA report of 29 August 2026; Section 5.2.2 of the dissertation): A-1: The controller acts in good faith to meet the legal requirements of the LGPD (Brazilian General Data Protection Law). A-2: The smartphone and the smart tourism system are already configured. A-3: The tourist keeps the smartphone and the GPS service active. A-4: The system has functionality to verify the geolocation consent. A-5: The mobile network and GPS infrastructure work adequately. A-6: The database system is active and performs correctly. A-7: The tourist understands the consent terms and is aware of their responsibilities when accepting them. A-8: There is no operator in the system. The controller performs all personal data processing. A-9: Users are adults (over 17 years old). A-10: No personal data is transmitted to external services. Local DFD/MTM assumptions (not part of STPA Step 1 or AppSTPA): MTM-A-16: Use of the application is restricted to persons aged 18 or older. A proportionate age-assurance mechanism is applied with data minimization, and the service does not intentionally process personal data of children or adolescents. MTM-A-17: Personalized routes, hotels, and points of interest are advisory recommendations. The tourist remains free to accept, ignore, or change preferences; the system does not make solely automated decisions that produce legal or similarly significant effects under the defined scope. MTM-A-18: The system does not intentionally infer or store sensitive-personal-data labels. Location and preference processing is limited to tourism personalization, and any feature capable of revealing religion, health, political opinion, sexual life, biometric/genetic data, or another sensitive category is suppressed or requires a new LGPD Article 11 assessment. MTM-A-19: For F1 and F2, Contains Cookies = Yes is a conservative modeling proxy for cookies or equivalent session artifacts used by a WebView or mobile session layer. It does not mean that the human user literally transmits browser cookies; the property must be revalidated if the implementation is purely native and cookie-free. MTM-A-20: The SEFD exchanges only public or non-personal tourism catalog, weather, and availability data. F5 and F6 do

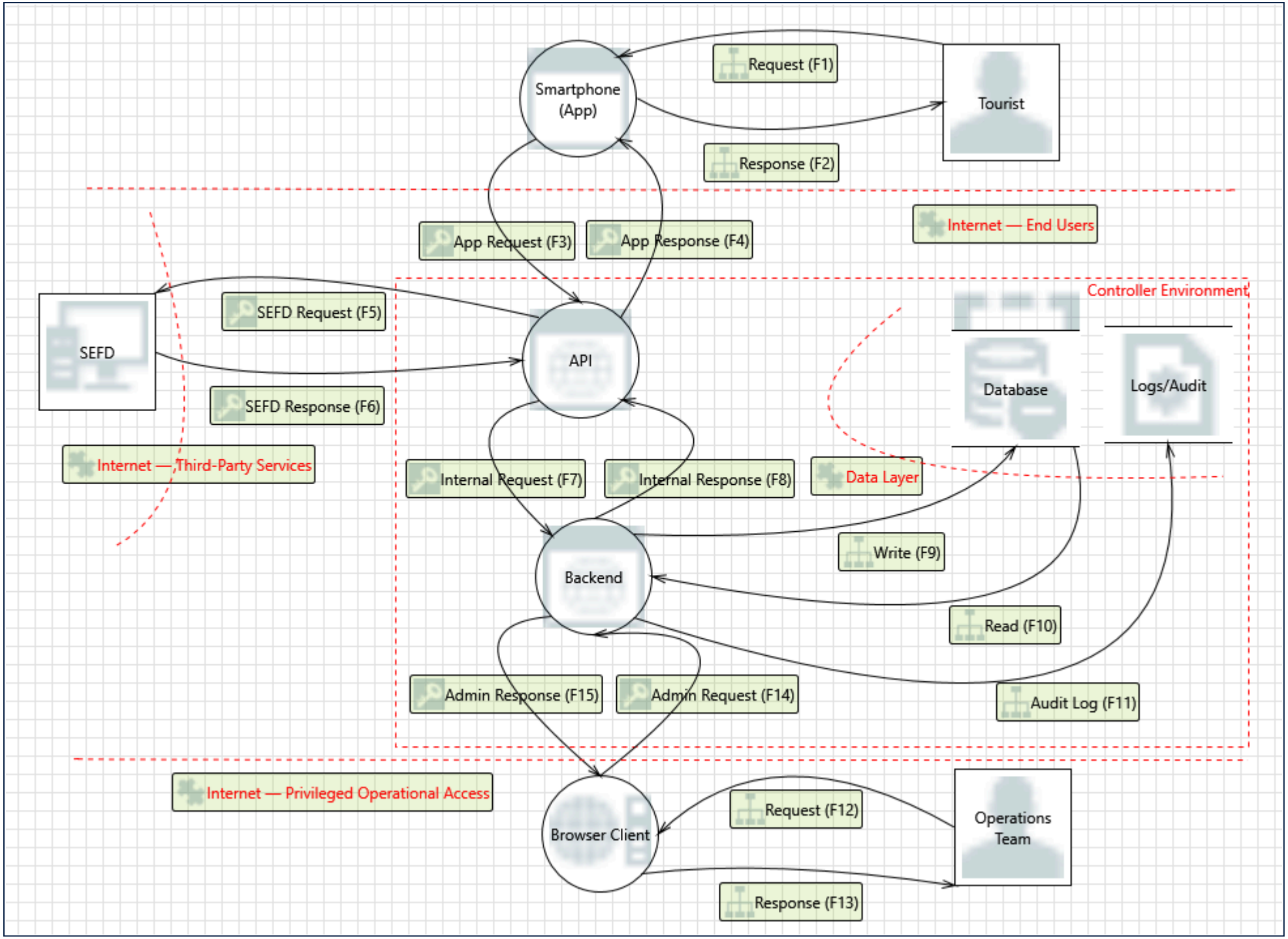
not contain tourist identifiers, precise tourist location, preference profiles, consent records, or authentication tokens; any change to this payload triggers reassessment of agent roles, operator instructions, and international-transfer requirements.

External Dependencies:

Threat Model Summary:

Not Started	0
Not Applicable	7
Needs Investigation	0
Mitigation Implemented	91
Total	98
Total Migrated	0

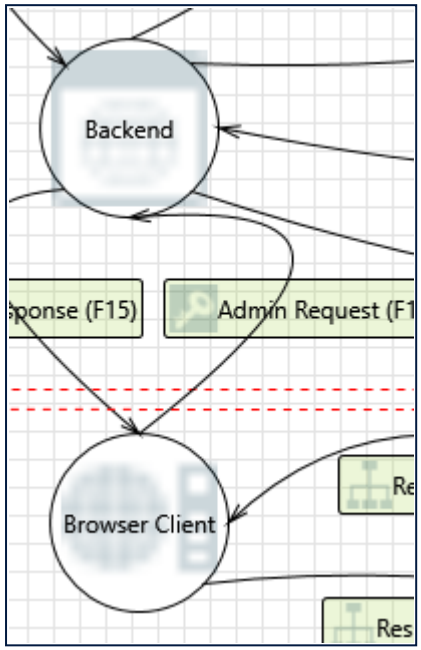
Diagram: App Turismo Inteligente


Smartphone (App)
Request (F1)
Tourist
Response (F2)
Internet — End Users
App Request (F3)
App Response (F4)
Controller Environment
SEFD
SEFD Request (F5)
API
Database
Logs/Audit
SEFD Response (F6)
Internet — Third-Party Services
Internal Request (F7)
Internal Response (F8)
Data Layer
Write (F9)
Backend
Read (F10)
Admin Response (F15)
Admin Request (F14)
Audit Log (F11)
Internet — Privileged Operational Access
Browser Client
Request (F12)
Operations Team
Response (F13)

App Turismo Inteligente Diagram Summary:

Not Started	0
Not Applicable	7
Needs Investigation	0
Mitigation Implemented	91
Total	98
Total Migrated	0

Interaction: Admin Request (F14)



1. Weak Authentication Scheme [State: Mitigation Implemented] [Priority: High]

Category: Information Disclosure

Description: Custom authentication schemes are susceptible to common weaknesses such as weak credential change management, credential equivalence, easily guessable credentials, null credentials, downgrade authentication or a weak credential change management system. Consider the impact and potential mitigations for your custom authentication scheme.

Justification: Analytical mitigation specified by CTL-STR-01 (CT-STR-01). Proposed control: robust authentication for data subjects, operators, and services before sensitive flows. Expected evidence: authentication policy, operational MFA, authentication tests and logs.

2. Elevation by Changing the Execution Flow in Backend [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: An attacker may pass data into Backend in order to change the flow of program execution within Backend to the attacker's choosing.

Justification: Analytical mitigation specified by CTL-STR-08.A, CTL-STR-08.B (CT-STR-08). Proposed control: least privilege, operational-access segregation, and input validation. Expected evidence: RBAC, administrative profiles, input validation, and cybersecurity tests.

3. Backend May be Subject to Elevation of Privilege Using Remote Code Execution [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: Browser Client may be able to remotely execute code for Backend.

Justification: Analytical mitigation specified by CTL-STR-08.A, CTL-STR-08.B (CT-STR-08). Proposed control: least privilege, operational-access segregation, and input validation. Expected evidence: RBAC, administrative profiles, input validation, and cybersecurity tests.

4. Elevation Using Impersonation [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: Backend may be able to impersonate the context of Browser Client in order to gain additional privilege.

Justification: Analytical mitigation specified by CTL-STR-08.A, CTL-STR-08.B (CT-STR-08). Proposed control: least privilege, operational-access segregation, and input validation. Expected evidence: RBAC, administrative profiles, input validation, and cybersecurity tests.

5. Data Flow Admin Request Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04). Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

6. Potential Process Crash or Stop for Backend [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: Backend crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04). Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

7. Potential Data Repudiation by Backend [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: Backend claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: Analytical mitigation specified by CTL-STR-10 (CT-STR-10). Proposed control: non-repudiation and traceability of relevant system actions. Expected evidence: correlated logs, transaction IDs/signatures, and auditable trails.

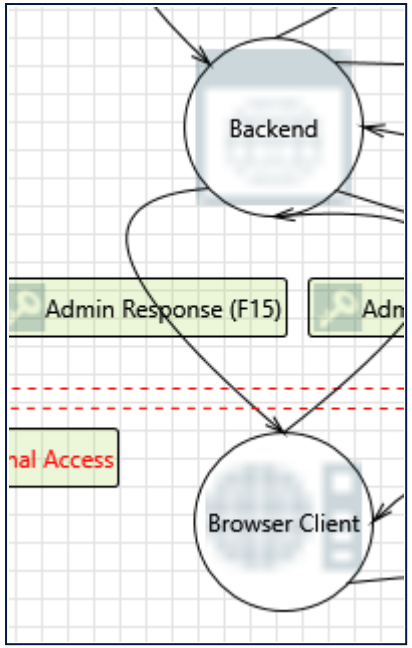
8. JavaScript Object Notation Processing [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: If a dataflow contains JSON, JSON processing and hijacking threats may be exploited.

Justification: Analytical mitigation specified by CTL-STR-03 (CT-STR-03), same threat family as representative ID 427. Proposed control: strict validation of JSON payloads and API contracts. Expected evidence: schemas, negative API tests, and content-type validation.

Interaction: Admin Response (F15)



9. Replay Attacks [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Packets or messages without sequence numbers or timestamps can be captured and replayed in a wide variety of ways. Implement or utilize an existing communication protocol that supports anti-replay techniques (investigate sequence numbers before timers) and strong integrity.

Justification: Analytical mitigation specified by CTL-STR-02 (CT-STR-02). Proposed control: message integrity, freshness, and anti-replay protection for critical flows. Expected evidence: nonce/timestamp, correlation IDs, anti-replay tests, and rejection logs.

10. Collision Attacks [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Attackers who can send a series of packets or messages may be able to overlap data. For example, packet 1 may be 100 bytes starting at offset 0. Packet 2 may be 100 bytes starting at offset 25. Packet 2 will overwrite 75 bytes of packet 1. Ensure you reassemble data before filtering it, and ensure you explicitly handle these sorts of cases.

Justification: Analytical mitigation specified by CTL-STR-02 (CT-STR-02), same threat family as representative ID 405. Proposed control: message integrity, freshness, and anti-replay protection for critical flows. Expected evidence: nonce/timestamp, correlation IDs, anti-replay tests, and rejection

logs.

11. Weak Authentication Scheme [State: Mitigation Implemented] [Priority: High]

Category: Information Disclosure

Description: Custom authentication schemes are susceptible to common weaknesses such as weak credential change management, credential equivalence, easily guessable credentials, null credentials, downgrade authentication or a weak credential change management system. Consider the impact and potential mitigations for your custom authentication scheme.

Justification: Analytical mitigation specified by CTL-STR-01 (CT-STR-01), same threat family as representative ID 404. Proposed control: robust authentication for data subjects, operators, and services before sensitive flows. Expected evidence: authentication policy, operational MFA, authentication tests and logs.

12. Elevation by Changing the Execution Flow in Browser Client [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: An attacker may pass data into Browser Client in order to change the flow of program execution within Browser Client to the attacker's choosing.

Justification: Analytical mitigation specified by CTL-STR-08.A, CTL-STR-08.B (CT-STR-08). Proposed control: least privilege, operational-access segregation, and input validation. Expected evidence: RBAC, administrative profiles, input validation, and cybersecurity tests.

13. Browser Client May be Subject to Elevation of Privilege Using Remote Code Execution [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: Backend may be able to remotely execute code for Browser Client.

Justification: Analytical mitigation specified by CTL-STR-08.A, CTL-STR-08.B (CT-STR-08). Proposed control: least privilege, operational-access segregation, and input validation. Expected evidence: RBAC, administrative profiles, input validation, and cybersecurity tests.

14. Elevation Using Impersonation [State: Not Applicable] [Priority: High]

Category: Elevation Of Privilege

Description: Browser Client may be able to impersonate the context of Backend in order to gain additional privilege.

Justification: NA-3. Not applicable: the Browser Client receives neither a service credential nor the Backend execution context. Applicable operational impersonation and authorization threats are addressed separately.

15. Data Flow Admin Response Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04), same threat family as representative ID 23. Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

16. Potential Process Crash or Stop for Browser Client [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: Browser Client crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04). Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

17. Potential Data Repudiation by Browser Client [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: Browser Client claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: Analytical mitigation specified by CTL-STR-10 (CT-STR-10). Proposed control: non-repudiation and traceability of relevant system actions. Expected evidence: correlated logs, transaction IDs/signatures, and auditable trails.

18. Backend Process Memory Tampered [State: Not Applicable] [Priority: High]

Category: Tampering

Description: If Backend is given access to memory, such as shared memory or pointers, or is given the ability to control what Browser Client executes (for example, passing back a function pointer.), then Backend can tamper with Browser Client. Consider if the function could work with less access to memory, such as passing data rather than pointers. Copy in data provided, and then validate it.

Justification: NA-2. Not applicable: the threat assumes shared memory or direct execution control, while the DFD models separate components without shared memory.

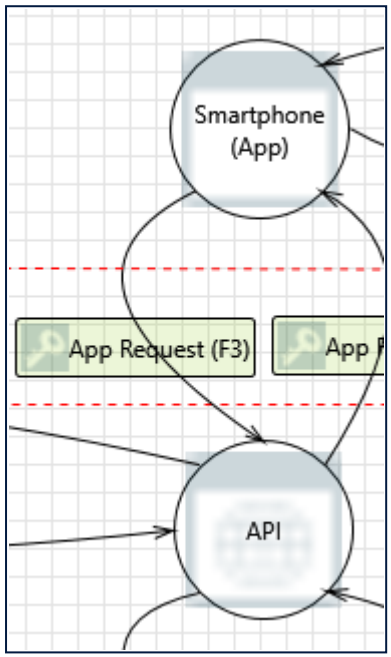
19. JavaScript Object Notation Processing [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: If a dataflow contains JSON, JSON processing and hijacking threats may be exploited.

Justification: Analytical mitigation specified by CTL-STR-03 (CT-STR-03), same threat family as representative ID 427. Proposed control: strict validation of JSON payloads and API contracts. Expected evidence: schemas, negative API tests, and content-type validation.

Interaction: App Request (F3)



20. Elevation by Changing the Execution Flow in API [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: An attacker may pass data into API in order to change the flow of program execution within API to the attacker's choosing.

Justification: Analytical mitigation specified by CTL-STR-08.A, CTL-STR-08.B (CT-STR-08). Proposed control: least privilege, operational-access segregation, and input validation. Expected evidence: RBAC, administrative profiles, input validation, and cybersecurity tests.

21. API May be Subject to Elevation of Privilege Using Remote Code Execution [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: Smartphone (App) may be able to remotely execute code for API.

Justification: Analytical mitigation specified by CTL-STR-08.A, CTL-STR-08.B (CT-STR-08). Proposed control: least privilege, operational-access segregation, and input validation. Expected evidence: RBAC, administrative profiles, input validation, and cybersecurity tests.

22. Elevation Using Impersonation [State: Not Applicable] [Priority: High]

Category: Elevation Of Privilege

Description: API may be able to impersonate the context of Smartphone (App) in order to gain additional privilege.

Justification: NA-3. Not applicable: the API does not receive, reuse, or delegate the Smartphone security context; client and service identities are distinct. Endpoint spoofing and malicious responses are addressed by applicable threats and CTL-STR controls.

23. Data Flow App Request Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04). Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

24. Potential Process Crash or Stop for API [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: API crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04). Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

25. Potential Data Repudiation by API [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: API claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: Analytical mitigation specified by CTL-STR-10 (CT-STR-10). Proposed control: non-repudiation and traceability of relevant system actions. Expected evidence: correlated logs, transaction IDs/signatures, and auditable trails.

26. Smartphone (App) Process Memory Tampered [State: Not Applicable] [Priority: High]

Category: Tampering

Description: If Smartphone (App) is given access to memory, such as shared memory or pointers, or is given the ability to control what API executes (for example, passing back a function pointer.), then Smartphone (App) can tamper with API. Consider if the function could work with less access to memory, such as passing data rather than pointers. Copy in data provided, and then validate it.

Justification: NA-2. Not applicable: the threat assumes shared memory or direct execution control, while the DFD models separate components without shared memory.

27. Replay Attacks [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Packets or messages without sequence numbers or timestamps can be captured and replayed in a wide variety of ways. Implement or utilize an existing communication protocol that supports anti-replay techniques (investigate sequence numbers before timers) and strong integrity.

Justification: Analytical mitigation specified by CTL-STR-02 (CT-STR-02). Proposed control: message integrity, freshness, and anti-replay protection for critical flows. Expected evidence: nonce/timestamp, correlation IDs, anti-replay tests, and rejection logs.

28. Collision Attacks [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Attackers who can send a series of packets or messages may be able to overlap data. For example, packet 1 may be 100 bytes starting at offset 0. Packet 2 may be 100 bytes starting at offset 25. Packet 2 will overwrite 75 bytes of packet 1. Ensure you reassemble data before filtering it, and ensure you explicitly handle these sorts of cases.

Justification: Analytical mitigation specified by CTL-STR-02 (CT-STR-02). Proposed control: message integrity, freshness, and anti-replay protection for critical flows. Expected evidence: nonce/timestamp, correlation IDs, anti-replay tests, and rejection logs.

29. Weak Authentication Scheme [State: Mitigation Implemented] [Priority: High]

Category: Information Disclosure

Description: Custom authentication schemes are susceptible to common weaknesses such as weak credential change management, credential equivalence, easily guessable credentials, null credentials, downgrade authentication or a weak credential change management system. Consider the impact and potential mitigations for your custom authentication scheme.

Justification: Analytical mitigation specified by CTL-STR-01 (CT-STR-01). Proposed control: robust authentication for data subjects, operators, and services before sensitive flows. Expected evidence: authentication policy, operational MFA, authentication tests and logs.

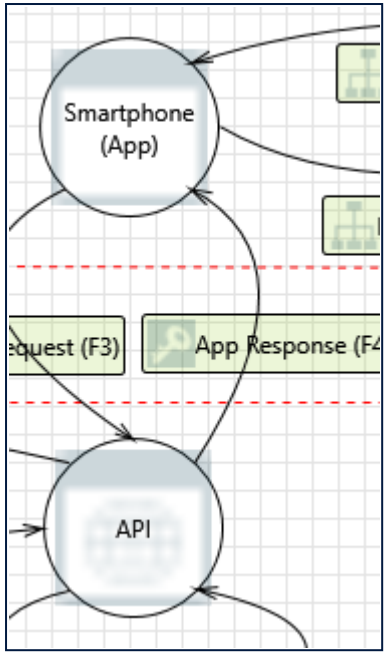
30. JavaScript Object Notation Processing [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: If a dataflow contains JSON, JSON processing and hijacking threats may be exploited.

Justification: Analytical mitigation specified by CTL-STR-03 (CT-STR-03). Proposed control: strict validation of JSON payloads and API contracts. Expected evidence: schemas, negative API tests, and content-type validation.

Interaction: App Response (F4)



31. Elevation by Changing the Execution Flow in Smartphone (App) [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: An attacker may pass data into Smartphone (App) in order to change the flow of program execution within Smartphone (App) to the attacker's choosing.

Justification: Analytical mitigation specified by CTL-STR-08.A, CTL-STR-08.B (CT-STR-08). Proposed control: least privilege, operational-access segregation, and input validation. Expected evidence: RBAC, administrative profiles, input validation, and cybersecurity tests.

32. Smartphone (App) May be Subject to Elevation of Privilege Using Remote Code Execution [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: API may be able to remotely execute code for Smartphone (App).

Justification: Analytical mitigation specified by CTL-STR-08.A, CTL-STR-08.B (CT-STR-08). Proposed control: least privilege, operational-access segregation, and input validation. Expected evidence: RBAC, administrative profiles, input validation, and cybersecurity tests.

33. Elevation Using Impersonation [State: Not Applicable] [Priority: High]

Category: Elevation Of Privilege

Description: Smartphone (App) may be able to impersonate the context of API in order to gain additional privilege.

Justification: NA-3. Not applicable: the Smartphone receives neither a service credential nor the API execution context. Endpoint spoofing and malicious responses are addressed by separate applicable threats and CTL-STR controls.

34. Data Flow App Response Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04). Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

35. Potential Process Crash or Stop for Smartphone (App) [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: Smartphone (App) crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04). Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

36. Potential Data Repudiation by Smartphone (App) [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: Smartphone (App) claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: Analytical mitigation specified by CTL-STR-10 (CT-STR-10). Proposed control: non-repudiation and traceability of relevant system actions. Expected evidence: correlated logs, transaction IDs/signatures, and auditable trails.

37. API Process Memory Tampered [State: Not Applicable] [Priority: High]

Category: Tampering

Description: If API is given access to memory, such as shared memory or pointers, or is given the ability to control what Smartphone (App) executes (for example, passing back a function pointer.), then API can tamper with Smartphone (App). Consider if the function could work with less access to memory, such as passing data rather than pointers. Copy in data provided, and then validate it.

Justification: NA-2. Not applicable: the threat assumes shared memory or direct execution control, while the DFD models separate components without shared memory.

38. Replay Attacks [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Packets or messages without sequence numbers or timestamps can be captured and replayed in a wide variety of ways. Implement or utilize an existing communication protocol that supports anti-replay techniques (investigate sequence numbers before timers) and strong integrity.

Justification: Analytical mitigation specified by CTL-STR-02 (CT-STR-02), same threat family as representative ID 405. Proposed control: message integrity, freshness, and anti-replay protection for critical flows. Expected evidence: nonce/timestamp, correlation IDs, anti-replay tests, and rejection logs.

39. Collision Attacks [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Attackers who can send a series of packets or messages may be able to overlap data. For example, packet 1 may be 100 bytes starting at offset 0. Packet 2 may be 100 bytes starting at offset 25. Packet 2 will overwrite 75 bytes of packet 1. Ensure you reassemble data before filtering it, and ensure you explicitly handle these sorts of cases.

Justification: Analytical mitigation specified by CTL-STR-02 (CT-STR-02), same threat family as representative ID 405. Proposed control: message integrity, freshness, and anti-replay protection for critical flows. Expected evidence: nonce/timestamp, correlation IDs, anti-replay tests, and rejection logs.

40. Weak Authentication Scheme [State: Mitigation Implemented] [Priority: High]

Category: Information Disclosure

Description: Custom authentication schemes are susceptible to common weaknesses such as weak credential change management, credential equivalence, easily guessable credentials, null credentials, downgrade authentication or a weak credential change management system.

Consider the impact and potential mitigations for your custom authentication scheme.

Justification: Analytical mitigation specified by CTL-STR-01 (CT-STR-01), same threat family as representative ID 404. Proposed control: robust authentication for data subjects, operators, and services before sensitive flows. Expected evidence: authentication policy, operational MFA, authentication tests and logs.

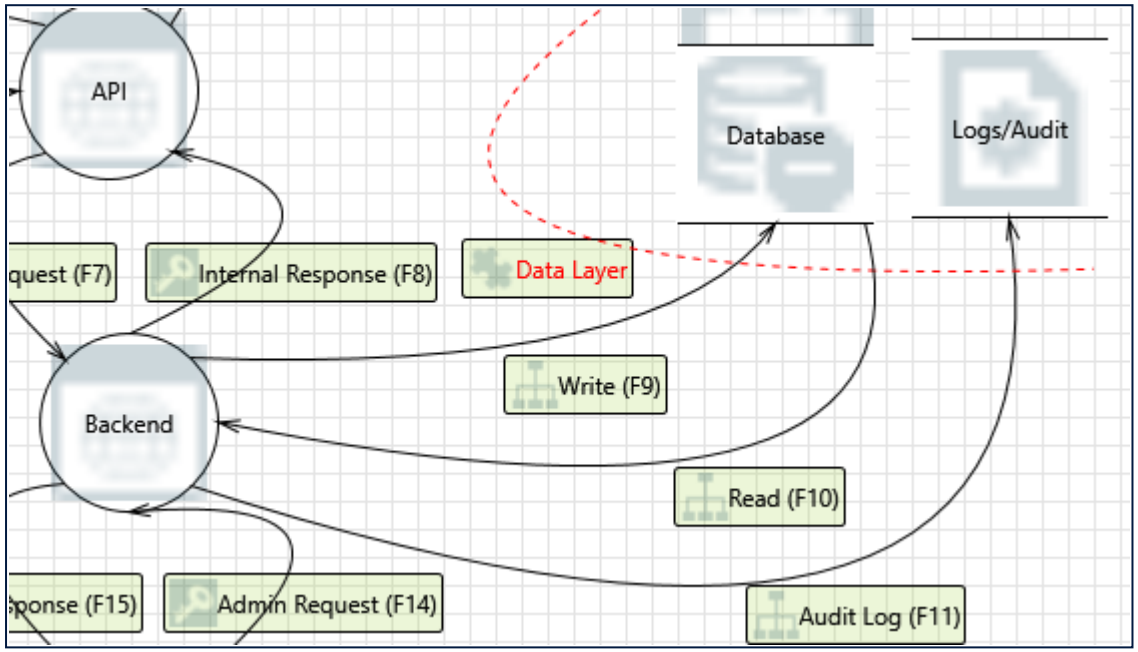
41. JavaScript Object Notation Processing [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: If a dataflow contains JSON, JSON processing and hijacking threats may be exploited.

Justification: Analytical mitigation specified by CTL-STR-03 (CT-STR-03), same threat family as representative ID 427. Proposed control: strict validation of JSON payloads and API contracts. Expected evidence: schemas, negative API tests, and content-type validation.

Interaction: Audit Log (F11)



42. Insufficient Auditing [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: Does the log capture enough data to understand what happened in the past? Do your logs capture enough data to understand an incident after the fact? Is such capture lightweight enough to be left on all the time? Do you have enough data to deal with repudiation claims? Make sure you log sufficient and appropriate data to handle a repudiation claims. You might want to talk to an audit expert as well as a privacy expert about your choice of data.

Justification: Analytical mitigation specified by CTL-STR-05.A (CT-STR-05.A). Proposed control: authenticated, integrity-protected, tamper-resistant audit trails. Expected evidence: signed logs, append-only trails, and integrity checks.

43. Data Logs from an Unknown Source [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: Do you accept logs from unknown or weakly authenticated users or systems? Identify and authenticate the source of the logs before accepting them.

Justification: Analytical mitigation specified by CTL-STR-05.A (CT-STR-05.A). Proposed control: authenticated, integrity-protected, tamper-resistant audit trails. Expected evidence: signed logs, append-only trails, and integrity checks.

44. Lower Trusted Subject Updates Logs [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: If you have trust levels, is anyone other outside of the highest trust level allowed to log? Letting everyone write to your logs can lead to repudiation problems. Only allow trusted code to log.

Justification: Analytical mitigation specified by CTL-STR-05.A (CT-STR-05.A). Proposed control: authenticated, integrity-protected, tamper-resistant audit trails. Expected evidence: signed logs, append-only trails, and integrity checks.

45. Potential Excessive Resource Consumption for Backend or Logs/Audit [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: Does Backend or Logs/Audit take explicit steps to control resource consumption? Resource consumption attacks can be hard to deal with, and there are times that it makes sense to let the OS do the job. Be careful that your resource requests don't deadlock, and that they do timeout.

Justification: Analytical mitigation specified by CTL-STR-05.C (CT-STR-05.C). Proposed control: continuity and recovery of log writing. Expected evidence: resilient buffering, rotation/retention, backups, and logging-failure tests.

46. Spoofing of Destination Data Store Logs/Audit [State: Mitigation Implemented] [Priority: High]

Category: Spoofing

Description: Logs/Audit may be spoofed by an attacker and this may lead to data being written to the attacker's target instead of Logs/Audit. Consider using a standard authentication mechanism to identify the destination data store.

Justification: Analytical mitigation specified by CTL-STR-05.A (CT-STR-05.A). Proposed control: authenticated, integrity-protected, tamper-resistant audit trails. Expected evidence: signed logs, append-only trails, and integrity checks.

47. Data Store Inaccessible [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: An external agent prevents access to a data store on the other side of the trust boundary.

Justification: Analytical mitigation specified by CTL-STR-05.C (CT-STR-05.C). Proposed control: continuity and recovery of log writing. Expected evidence: resilient buffering, rotation/retention, backups, and logging-failure tests.

48. Data Flow Audit Log Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: Analytical mitigation specified by CTL-STR-05.C (CT-STR-05.C). Proposed control: continuity and recovery of log writing. Expected evidence: resilient buffering, rotation/retention, backups, and logging-failure tests.

49. Weak Credential Transit [State: Mitigation Implemented] [Priority: High]

Category: Information Disclosure

Description: Credentials on the wire are often subject to sniffing by an attacker. Are the credentials re-usable/re-playable? Are credentials included in a message? For example, sending a zip file with the password in the email. Use strong cryptography for the transmission of credentials. Use

the OS libraries if at all possible, and consider cryptographic algorithm agility, rather than hardcoding a choice.

Justification: Analytical mitigation specified by CTL-STR-05.B (CT-STR-05.B). Proposed control: confidentiality and access protection for audit logs. Expected evidence: encryption, RBAC, access reviews, and unauthorized-access tests.

50. Data Flow Sniffing [State: Mitigation Implemented] [Priority: High]

Category: Information Disclosure

Description: Data flowing across Audit Log may be sniffed by an attacker. Depending on what type of data an attacker can read, it may be used to attack other parts of the system or simply be a disclosure of information leading to compliance violations. Consider encrypting the data flow.

Justification: Analytical mitigation specified by CTL-STR-05.B (CT-STR-05.B). Proposed control: confidentiality and access protection for audit logs. Expected evidence: encryption, RBAC, access reviews, and unauthorized-access tests.

51. Data Store Denies Logs/Audit Potentially Writing Data [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: Logs/Audit claims that it did not write data received from an entity on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: Analytical mitigation specified by CTL-STR-05.A (CT-STR-05.A). Proposed control: authenticated, integrity-protected, tamper-resistant audit trails. Expected evidence: signed logs, append-only trails, and integrity checks.

52. Risks from Logging [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Log readers can come under attack via log files. Consider ways to canonicalize data in all logs. Implement a single reader for the logs, if possible, in order to reduce attack surface area. Be sure to understand and document log file elements which come from untrusted sources.

Justification: Analytical mitigation specified by CTL-STR-05.A (CT-STR-05.A). Proposed control: authenticated, integrity-protected, tamper-resistant audit trails. Expected evidence: signed logs, append-only trails, and integrity checks.

53. Authorization Bypass [State: Mitigation Implemented] [Priority: High]

Category: Information Disclosure

Description: Can you access Logs/Audit and bypass the permissions for the object? For example by editing the files directly with a hex editor, or reaching it via filesharing? Ensure that your program is the only one that can access the data, and that all other subjects have to use your interface.

Justification: Analytical mitigation specified by CTL-STR-05.B (CT-STR-05.B). Proposed control: confidentiality and access protection for audit logs. Expected evidence: encryption, RBAC, access reviews, and unauthorized-access tests.

54. The Logs/Audit Data Store Could Be Corrupted [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Data flowing across Audit Log may be tampered with by an attacker. This may lead to corruption of Logs/Audit. Ensure the integrity of the data flow to the data store.

Justification: Analytical mitigation specified by CTL-STR-05.A (CT-STR-05.A). Proposed control: authenticated, integrity-protected, tamper-resistant audit trails. Expected evidence: signed logs, append-only trails, and integrity checks.

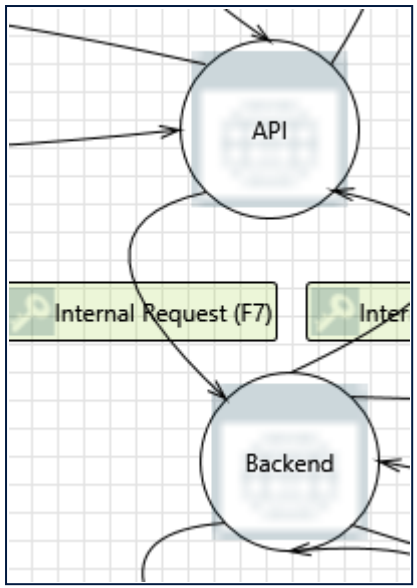
55. Potential Weak Protections for Audit Data [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: Consider what happens when the audit mechanism comes under attack, including attempts to destroy the logs, or attack log analysis programs. Ensure access to the log is through a reference monitor, which controls read and write separately. Document what filters, if any, readers can rely on, or writers should expect

Justification: Analytical mitigation specified by CTL-STR-05.A (CT-STR-05.A). Proposed control: authenticated, integrity-protected, tamper-resistant audit trails. Expected evidence: signed logs, append-only trails, and integrity checks.

Interaction: Internal Request (F7)



56. Elevation Using Impersonation [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: Backend may be able to impersonate the context of API in order to gain additional privilege.

Justification: Analytical mitigation specified by CTL-STR-08.A, CTL-STR-08.B (CT-STR-08). Proposed control: least privilege, operational-access segregation, and input validation. Expected evidence: RBAC, administrative profiles, input validation, and cybersecurity tests.

57. Collision Attacks [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Attackers who can send a series of packets or messages may be able to overlap data. For example, packet 1 may be 100 bytes starting at offset 0. Packet 2 may be 100 bytes starting at offset 25. Packet 2 will overwrite 75 bytes of packet 1. Ensure you reassemble data before filtering it, and ensure you explicitly handle these sorts of cases.

Justification: Analytical mitigation specified by CTL-STR-02 (CT-STR-02), same threat family as representative ID 405. Proposed control: message integrity, freshness, and anti-replay protection for critical flows. Expected evidence: nonce/timestamp, correlation IDs, anti-replay tests, and rejection logs.

58. Replay Attacks [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Packets or messages without sequence numbers or timestamps can be captured and replayed in a wide variety of ways. Implement or utilize an existing communication protocol that supports anti-replay techniques (investigate sequence numbers before timers) and strong integrity.

Justification: Analytical mitigation specified by CTL-STR-02 (CT-STR-02), same threat family as representative ID 405. Proposed control: message integrity, freshness, and anti-replay protection for critical flows. Expected evidence: nonce/timestamp, correlation IDs, anti-replay tests, and rejection logs.

59. Weak Authentication Scheme [State: Mitigation Implemented] [Priority: High]

Category: Information Disclosure

Description: Custom authentication schemes are susceptible to common weaknesses such as weak credential change management, credential equivalence, easily guessable credentials, null credentials, downgrade authentication or a weak credential change management system. Consider the impact and potential mitigations for your custom authentication scheme.

Justification: Analytical mitigation specified by CTL-STR-01 (CT-STR-01), same threat family as representative ID 404. Proposed control: robust authentication for data subjects, operators, and services before sensitive flows. Expected evidence: authentication policy, operational MFA, authentication tests and logs.

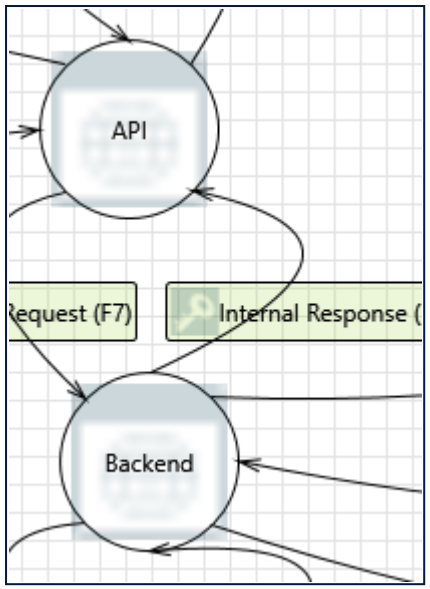
60. JavaScript Object Notation Processing [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: If a dataflow contains JSON, JSON processing and hijacking threats may be exploited.

Justification: Analytical mitigation specified by CTL-STR-03 (CT-STR-03), same threat family as representative ID 427. Proposed control: strict validation of JSON payloads and API contracts. Expected evidence: schemas, negative API tests, and content-type validation.

Interaction: Internal Response (F8)



61. Elevation Using Impersonation [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: API may be able to impersonate the context of Backend in order to gain additional privilege.

Justification: Analytical mitigation specified by CTL-STR-08.A, CTL-STR-08.B (CT-STR-08), same threat family as representative ID 357. Proposed control: least privilege, operational-access segregation, and input validation. Expected evidence: RBAC, administrative profiles, input validation, and cybersecurity tests.

62. Backend Process Memory Tampered [State: Not Applicable] [Priority: High]

Category: Tampering

Description: If Backend is given access to memory, such as shared memory or pointers, or is given the ability to control what API executes (for example, passing back a function pointer.), then Backend can tamper with API. Consider if the function could work with less access to memory, such as passing data rather than pointers. Copy in data provided, and then validate it.

Justification: NA-2. Not applicable: the threat assumes shared memory or direct execution control, while the DFD models separate components without shared memory.

63. Collision Attacks [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Attackers who can send a series of packets or messages may be able to overlap data. For example, packet 1 may be 100 bytes starting at offset 0. Packet 2 may be 100 bytes starting at offset 25. Packet 2 will overwrite 75 bytes of packet 1. Ensure you reassemble data before filtering it, and ensure you explicitly handle these sorts of cases.

Justification: Analytical mitigation specified by CTL-STR-02 (CT-STR-02), same threat family as representative ID 405. Proposed control: message integrity, freshness, and anti-replay protection for critical flows. Expected evidence: nonce/timestamp, correlation IDs, anti-replay tests, and rejection logs.

64. Weak Authentication Scheme [State: Mitigation Implemented] [Priority: High]

Category: Information Disclosure

Description: Custom authentication schemes are susceptible to common weaknesses such as weak credential change management, credential equivalence, easily guessable credentials, null credentials, downgrade authentication or a weak credential change management system. Consider the impact and potential mitigations for your custom authentication scheme.

Justification: Analytical mitigation specified by CTL-STR-01 (CT-STR-01), same threat family as representative ID 404. Proposed control: robust authentication for data subjects, operators, and services before sensitive flows. Expected evidence: authentication policy, operational MFA, authentication tests and logs.

65. Replay Attacks [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Packets or messages without sequence numbers or timestamps can be captured and replayed in a wide variety of ways. Implement or utilize an existing communication protocol that supports anti-replay techniques (investigate sequence numbers before timers) and strong integrity.

Justification: Analytical mitigation specified by CTL-STR-02 (CT-STR-02), same threat family as representative ID 405. Proposed control: message integrity, freshness, and anti-replay protection for critical flows. Expected evidence: nonce/timestamp, correlation IDs, anti-replay tests, and rejection logs.

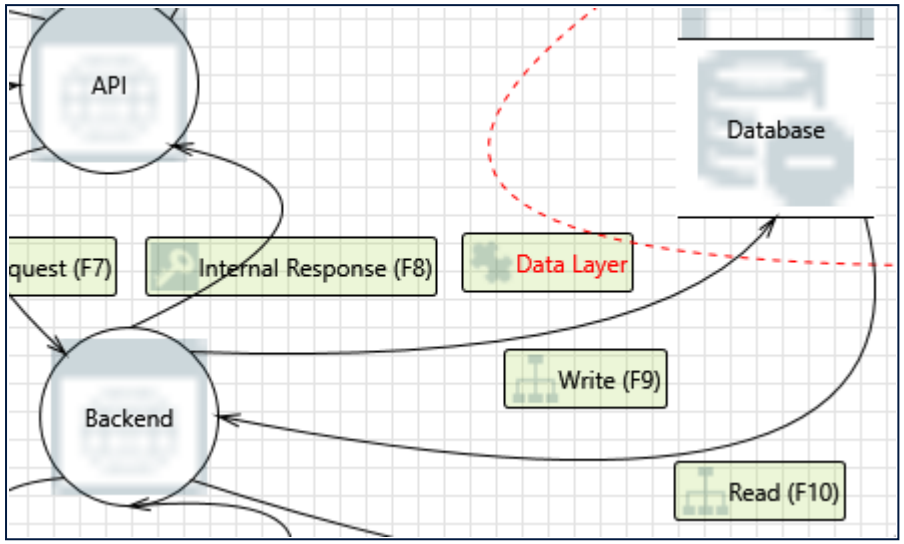
66. JavaScript Object Notation Processing [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: If a dataflow contains JSON, JSON processing and hijacking threats may be exploited.

Justification: Analytical mitigation specified by CTL-STR-03 (CT-STR-03), same threat family as representative ID 427. Proposed control: strict validation of JSON payloads and API contracts. Expected evidence: schemas, negative API tests, and content-type validation.

Interaction: Read (F10)



67. Potential Data Repudiation by Backend [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: Backend claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: Analytical mitigation specified by CTL-STR-10 (CT-STR-10), same threat family as representative ID 353. Proposed control: non-repudiation and traceability of relevant system actions. Expected evidence: correlated logs, transaction IDs/signatures, and auditable trails.

68. Spoofing of Source Data Store Database [State: Mitigation Implemented] [Priority: High]

Category: Spoofing

Description: Database may be spoofed by an attacker and this may lead to incorrect data delivered to Backend. Consider using a standard authentication mechanism to identify the source data store.

Justification: Analytical mitigation specified by CTL-STR-06 (CT-STR-06). Proposed control: protection of personal-data persistence and operational states. Expected evidence: encryption, granular access control, backups, and authorization/recovery tests.

69. Spoofing the Backend Process [State: Mitigation Implemented] [Priority: High]

Category: Spoofing

Description: Backend may be spoofed by an attacker and this may lead to information disclosure by Database. Consider using a standard authentication mechanism to identify the destination process.

Justification: Analytical mitigation specified by CTL-STR-06 (CT-STR-06). Proposed control: protection of personal-data persistence and operational states. Expected evidence: encryption, granular access control, backups, and authorization/recovery tests.

70. Elevation by Changing the Execution Flow in Backend [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: An attacker may pass data into Backend in order to change the flow of program execution within Backend to the attacker's choosing.

Justification: Analytical mitigation specified by CTL-STR-08.A, CTL-STR-08.B (CT-STR-08), same threat family as representative ID 357. Proposed control: least privilege, operational-access segregation, and input validation. Expected evidence: RBAC, administrative profiles, input validation, and cybersecurity tests.

71. Backend May be Subject to Elevation of Privilege Using Remote Code Execution [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: Database may be able to remotely execute code for Backend.

Justification: Analytical mitigation specified by CTL-STR-06 (CT-STR-06). Proposed control: protection of personal-data persistence and operational states. Expected evidence: encryption, granular access control, backups, and authorization/recovery tests.

72. Data Store Inaccessible [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: An external agent prevents access to a data store on the other side of the trust boundary.

Justification: Analytical mitigation specified by CTL-STR-06 (CT-STR-06), same threat family as representative ID 22. Proposed control: protection of personal-data persistence and operational states. Expected evidence: encryption, granular access control, backups, and authorization/recovery tests.

73. Data Flow Read Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04), same threat family as representative ID 23. Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

74. Potential Process Crash or Stop for Backend [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: Backend crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04), same threat family as representative ID 23. Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

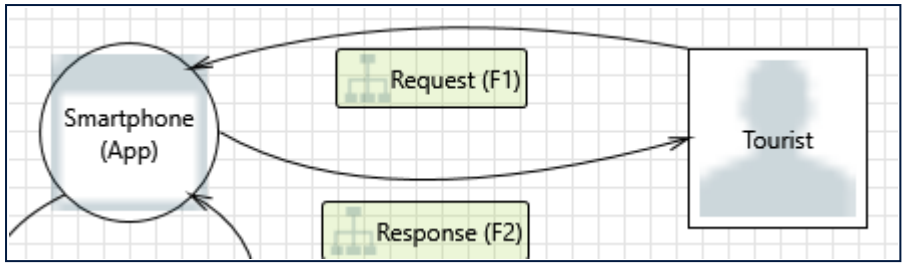
75. Weak Access Control for a Resource [State: Mitigation Implemented] [Priority: High]

Category: Information Disclosure

Description: Improper data protection of Database can allow an attacker to read information not intended for disclosure. Review authorization settings.

Justification: Analytical mitigation specified by CTL-STR-06 (CT-STR-06). Proposed control: protection of personal-data persistence and operational states. Expected evidence: encryption, granular access control, backups, and authorization/recovery tests.

Interaction: Request (F1)



76. Spoofing the Tourist External Entity [State: Mitigation Implemented] [Priority: High]

Category: Spoofing

Description: Tourist may be spoofed by an attacker and this may lead to unauthorized access to Smartphone (App). Consider using a standard authentication mechanism to identify the external entity.

Justification: Analytical mitigation specified by CTL-STR-09 (CT-STR-09). Proposed control: sensitive actions must be performed by an authenticated and authorized data subject or operator, with explicit confirmation and risk-based reauthentication. Expected evidence: strong authentication, MFA for operational access, reauthentication and confirmation records, session controls and audit trails, request-forgery protection, and secure session binding when justified by the risk analysis.

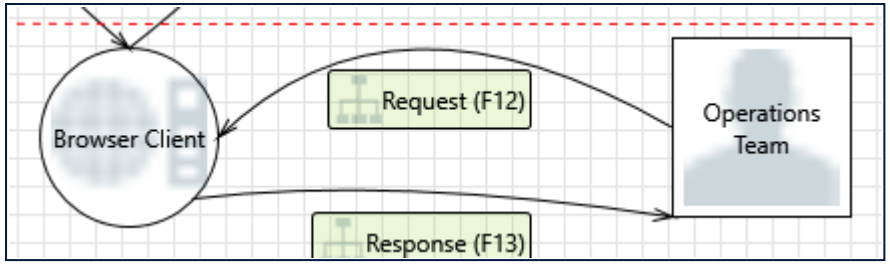
77. Elevation Using Impersonation [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: Smartphone (App) may be able to impersonate the context of Tourist in order to gain additional privilege.

Justification: Analytical mitigation specified by CTL-STR-09 (CT-STR-09), same threat family as representative ID 445. Proposed control: sensitive actions must be performed by an authenticated and authorized data subject or operator, with explicit confirmation and risk-based reauthentication. Expected evidence: strong authentication, MFA for operational access, reauthentication and confirmation records, session controls and audit trails, request-forgery protection, and secure session binding when justified by the risk analysis.

Interaction: Request (F12)



78. Elevation Using Impersonation [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: Browser Client may be able to impersonate the context of Operations Team in order to gain additional privilege.

Justification: Analytical mitigation specified by CTL-STR-09 (CT-STR-09), same threat family as representative ID 445. Proposed control: sensitive actions must be performed by an authenticated and authorized data subject or operator, with explicit confirmation and risk-based reauthentication. Expected evidence: strong authentication, MFA for operational access, reauthentication and confirmation records, session controls and audit trails, request-forgery protection, and secure session binding when justified by the risk analysis.

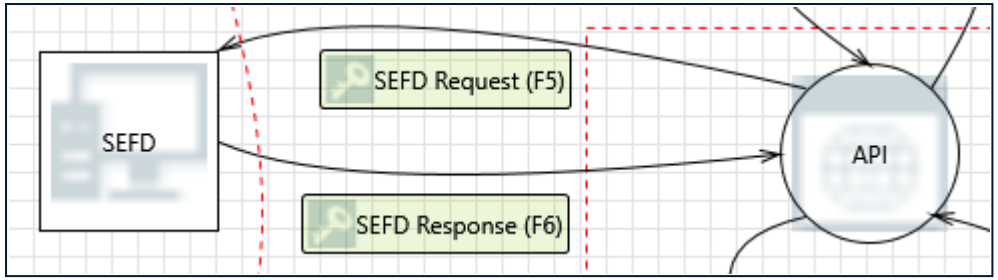
79. Spoofing the Operations Team External Entity [State: Mitigation Implemented] [Priority: High]

Category: Spoofing

Description: Operations Team may be spoofed by an attacker and this may lead to unauthorized access to Browser Client. Consider using a standard authentication mechanism to identify the external entity.

Justification: Analytical mitigation specified by CTL-STR-09 (CT-STR-09). Proposed control: sensitive actions must be performed by an authenticated and authorized data subject or operator, with explicit confirmation and risk-based reauthentication. Expected evidence: strong authentication, MFA for operational access, reauthentication and confirmation records, session controls and audit trails, request-forgery protection, and secure session binding when justified by the risk analysis.

Interaction: SEFD Request (F5)



80. External Entity SEFD Potentially Denies Receiving Data [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: SEFD claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: Analytical mitigation specified by CTL-STR-07 (CT-STR-07). Proposed control: record delivery to the SEFD with a correlation ID and confirm receipt when applicable. Expected evidence: correlated request/response records, verifiable send record, receipt confirmation, authenticated endpoint, validated schema, and negative/fuzz tests.

81. Spoofing of the SEFD External Destination Entity [State: Mitigation Implemented] [Priority: High]

Category: Spoofing

Description: SEFD may be spoofed by an attacker and this may lead to data being sent to the attacker's target instead of SEFD. Consider using a standard authentication mechanism to identify the external entity.

Justification: Analytical mitigation specified by CTL-STR-07 (CT-STR-07). Proposed control: authenticate the SEFD service, validate the origin, integrity, structure, content, and bounds of responses, and isolate the processing of external content to prevent tampering with the execution flow or recommendation logic. Expected evidence: endpoint authentication with mTLS or equivalent, certificate and origin validation, schema/type/size/bounds validation, hardened parser and safe deserialization, isolation of external-content processing, negative tests and fuzzing, and correlated logs with anomaly monitoring.

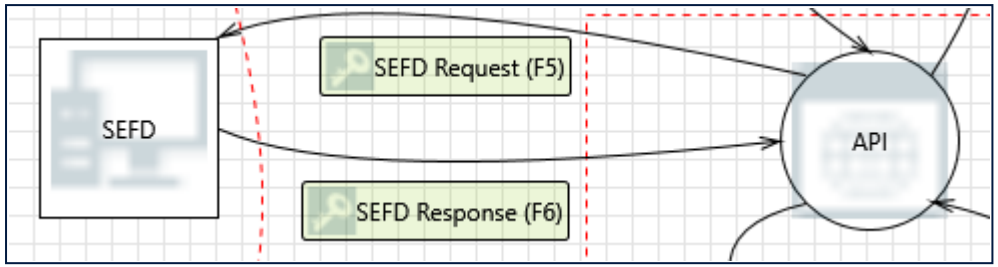
82. Data Flow SEFD Request Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04), same threat family as representative ID 23. Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

Interaction: SEFD Response (F6)



83. JavaScript Object Notation Processing [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: If a dataflow contains JSON, JSON processing and hijacking threats may be exploited.

Justification: Analytical mitigation specified by CTL-STR-07 (CT-STR-07). Proposed control: authenticate the SEFD service, validate the origin, integrity, structure, content, and bounds of responses, and isolate the processing of external content to prevent tampering with the execution flow or recommendation logic. Expected evidence: endpoint authentication with mTLS or equivalent, certificate and origin validation, schema/type/size/bounds validation, hardened parser and safe deserialization, isolation of external-content processing, negative tests and fuzzing, and correlated logs with anomaly monitoring.

84. Potential Data Repudiation by API [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: API claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: Analytical mitigation specified by CTL-STR-10 (CT-STR-10), same threat family as representative ID 353. Proposed control: non-repudiation and traceability of relevant system actions. Expected evidence: correlated logs, transaction IDs/signatures, and auditable trails.

85. Potential Process Crash or Stop for API [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: API crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04), same threat family as representative ID 23. Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

86. Data Flow SEFD Response Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04), same threat family as representative ID 23. Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

87. Elevation Using Impersonation [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: API may be able to impersonate the context of SEFD in order to gain additional privilege.

Justification: Analytical mitigation specified by CTL-STR-07 (CT-STR-07). Proposed control: authenticate the SEFD service, validate the origin, integrity, structure, content, and bounds of responses, and isolate the processing of external content to prevent tampering with the execution flow or recommendation logic. Expected evidence: endpoint authentication with mTLS or equivalent, certificate and origin validation, schema/type/size/bounds validation, hardened parser and safe deserialization, isolation of external-content processing, negative tests and fuzzing, and correlated logs with anomaly monitoring.

88. API May be Subject to Elevation of Privilege Using Remote Code Execution [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: SEFD may be able to remotely execute code for API.

Justification: Analytical mitigation specified by CTL-STR-07 (CT-STR-07). Proposed control: authenticate the SEFD service, validate the origin, integrity, structure, content, and bounds of responses, and isolate the processing of external content to prevent tampering with the execution flow or recommendation logic. Expected evidence: endpoint authentication with mTLS or equivalent, certificate and origin validation, schema/type/size/bounds validation, hardened parser and safe deserialization, isolation of external-content processing, negative tests and fuzzing, and correlated logs with anomaly monitoring.

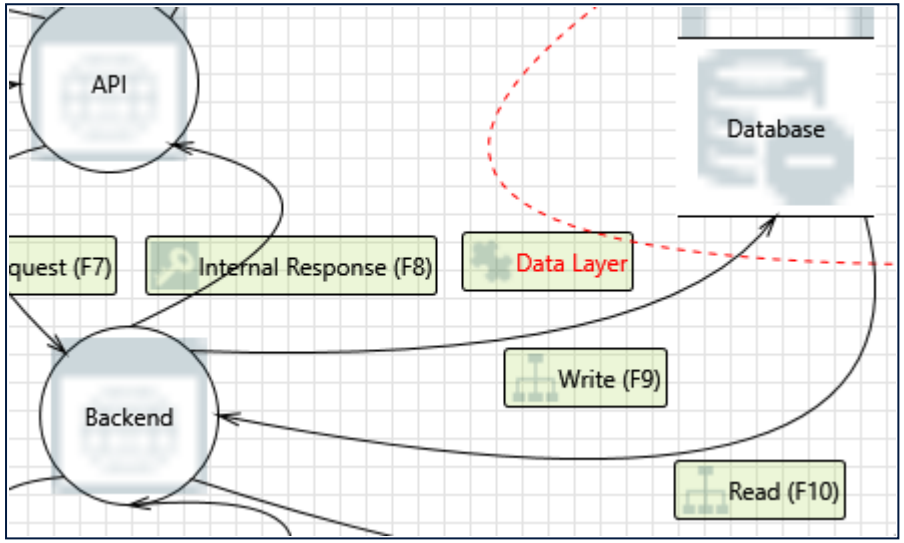
89. Elevation by Changing the Execution Flow in API [State: Mitigation Implemented] [Priority: High]

Category: Elevation Of Privilege

Description: An attacker may pass data into API in order to change the flow of program execution within API to the attacker's choosing.

Justification: Analytical mitigation specified by CTL-STR-07 (CT-STR-07). Proposed control: authenticate the SEFD service, validate the origin, integrity, structure, content, and bounds of responses, and isolate the processing of external content to prevent tampering with the execution flow or recommendation logic. Expected evidence: endpoint authentication with mTLS or equivalent, certificate and origin validation, schema/type/size/bounds validation, hardened parser and safe deserialization, isolation of external-content processing, negative tests and fuzzing, and correlated logs with anomaly monitoring.

Interaction: Write (F9)



90. Spoofing of Destination Data Store Database [State: Mitigation Implemented] [Priority: High]

Category: Spoofing

Description: Database may be spoofed by an attacker and this may lead to data being written to the attacker's target instead of Database. Consider using a standard authentication mechanism to identify the destination data store.

Justification: Analytical mitigation specified by CTL-STR-06 (CT-STR-06). Proposed control: protection of personal-data persistence and operational states. Expected evidence: encryption, granular access control, backups, and authorization/recovery tests.

91. Potential Excessive Resource Consumption for Backend or Database [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: Does Backend or Database take explicit steps to control resource consumption? Resource consumption attacks can be hard to deal with, and there are times that it makes sense to let the OS do the job. Be careful that your resource requests don't deadlock, and that they do timeout.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04). Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

92. Data Store Inaccessible [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: An external agent prevents access to a data store on the other side of the trust boundary.

Justification: Analytical mitigation specified by CTL-STR-06 (CT-STR-06). Proposed control: protection of personal-data persistence and operational states. Expected evidence: encryption, granular access control, backups, and authorization/recovery tests.

93. Data Flow Write Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: Analytical mitigation specified by CTL-STR-04.A, CTL-STR-04.B (CT-STR-04). Proposed control: resource-consumption limits and controlled degradation of critical flows. Expected evidence: rate limits, quotas, timeouts, load tests, fallback, and recovery tests.

94. Weak Credential Transit [State: Mitigation Implemented] [Priority: High]

Category: Information Disclosure

Description: Credentials on the wire are often subject to sniffing by an attacker. Are the credentials re-usable/re-playable? Are credentials included in a message? For example, sending a zip file with the password in the email. Use strong cryptography for the transmission of credentials. Use the OS libraries if at all possible, and consider cryptographic algorithm agility, rather than hardcoding a choice.

Justification: Analytical mitigation specified by CTL-STR-06 (CT-STR-06). Proposed control: protection of personal-data persistence and operational states. Expected evidence: encryption, granular access control, backups, and authorization/recovery tests.

95. Data Flow Sniffing [State: Mitigation Implemented] [Priority: High]

Category: Information Disclosure

Description: Data flowing across Write may be sniffed by an attacker. Depending on what type of data an attacker can read, it may be used to attack other parts of the system or simply be a disclosure of information leading to compliance violations. Consider encrypting the data flow.

Justification: Analytical mitigation specified by CTL-STR-06 (CT-STR-06). Proposed control: protection of personal-data persistence and operational states. Expected evidence: encryption, granular access control, backups, and authorization/recovery tests.

96. Data Store Denies Database Potentially Writing Data [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: Database claims that it did not write data received from an entity on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: Analytical mitigation specified by CTL-STR-06 (CT-STR-06). Proposed control: protect personal-data persistence and produce verifiable transactional confirmation for every critical write. Expected evidence: transaction ID, write acknowledgment, correlated audit trail, encryption, granular authorization, tested backup, and recovery tests.

97. The Database Data Store Could Be Corrupted [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Data flowing across Write may be tampered with by an attacker. This may lead to corruption of Database. Ensure the integrity of the data flow to the data store.

Justification: Analytical mitigation specified by CTL-STR-06 (CT-STR-06). Proposed control: protection of personal-data persistence and operational states. Expected evidence: encryption, granular access control, backups, and authorization/recovery tests.

98. Authorization Bypass [State: Mitigation Implemented] [Priority: High]

Category: Information Disclosure

Description: Can you access Database and bypass the permissions for the object? For example by editing the files directly with a hex editor, or reaching it via filesharing? Ensure that your program is the only one that can access the data, and that all other subjects have to use your interface.

Justification: Analytical mitigation specified by CTL-STR-06 (CT-STR-06). Proposed control: protection of personal-data persistence and operational states. Expected evidence: encryption, granular access control, backups, and authorization/recovery tests.